



Имовина, границе поверења и threat modeling

Прво разумемо шта штитимо, затим бирамо контроле

Проблем који решавамо

Добра безбедносна одлука не полази од листе познатих решења, већ од вредне имовине, тока података и граница поверења. Тек тада тим може да препозна шта би могло поћи по злу и која контрола има смисла за конкретан ризик.

ПРОБЛЕМ

Шта може поћи по злу

Добра безбедносна одлука не полази од листе познатих решења, већ од вредне имовине, тока података и граница поверења. Тек тада тим може да препозна шта би могло поћи по злу и која контрола има смисла за конкретан ризик.

ЗАШТО

Зашто је тема важна

Threat modeling повезује техничку структуру система са пословним последицама. Помаже тиму да раније уочи погрешне претпоставке, уместо да безбедност додаје након што се архитектура већ учврсти.

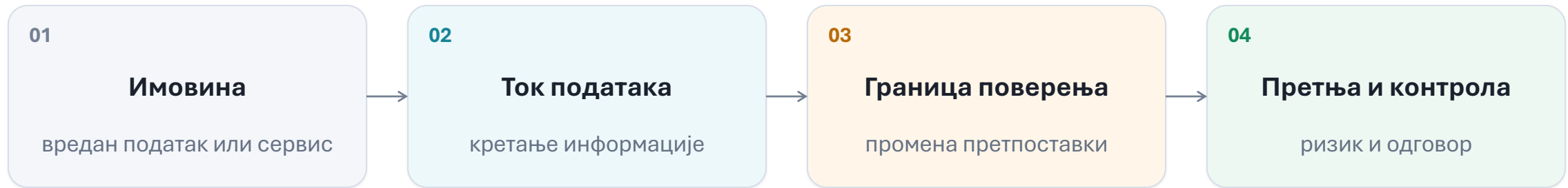
ИСХОД

Шта треба доказати

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

Четири појма граде једну одлуку

Сваки елемент одговара на друго питање и оставља другачији доказ.



КЉУЧНА ПОРУКА

Претња добија смисао тек када се веже за конкретну имовину, ток и последицу.

Имовина

вредан податак или сервис

01

Имовина има власника, значај и животни циклус.

Питање: који улаз покреће ову одлуку?

02

Имовина се не своди на базу података: укључује налоге, кључеве, сервисне идентитете, конфигурацију и пословне записе.

Питање: која граница мора бити видљива?

03

Критичност имовине одређује колико брзо се реагује и колико је доказа потребно.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Нацртајте један ток осетљивог податка и означите место на коме се претпоставка о поверењу мења.

Ток података

кретање информације

01

Спољна компонента не добија поверење само зато што је интегрисана.

Питање: који улаз покреће ову одлуку?

02

Граница поверења може бити API позив, ред порука, административни интерфејс или извоз у датотеку.

Питање: која граница мора бити видљива?

03

Ток података открива места на којима информација може бити измењена, изгубљена или погрешно изложена.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Нацртајте један ток осетљивог податка и означите место на коме се претпоставка о поверењу мења.

Граница поверења

промена претпоставки

01

Претња постаје корисна када води до захтева, контроле и начина провере.

Питање: који улаз покреће ову одлуку?

02

Добар тхреат модел бира неколико реалних сценарија и уз сваки наводи контролу и начин провере.

Питање: која граница мора бити видљива?

03

Претња добија приоритет према утицају, вероватноћи и реалним постојећим контролама.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Нацртајте један ток осетљивог податка и означите место на коме се претпоставка о поверењу мења.

Претња и контрола

ризик и одговор

01

Критичност имовине одређује колико брзо се реагује и колико је доказа потребно.

Питање: који улаз покреће ову одлуку?

02

Ток података открива места на којима информација може бити измењена, изгубљена или погрешно изложена.

Питање: која граница мора бити видљива?

03

Претња добија приоритет према утицају, вероватноћи и реалним постојећим контролама.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Нацртајте један ток осетљивог податка и означите место на коме се претпоставка о поверењу мења.

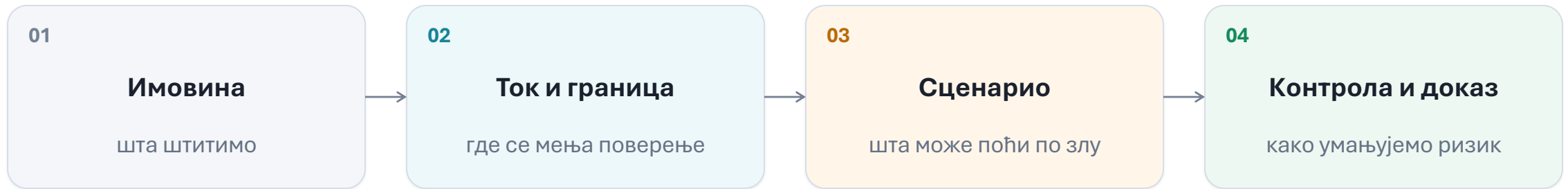
Имовина, рањивост и претња

Поређење служи да се разлике виде без тешке табеле и ситног текста.

Појам	Значење	Питање за анализу
Имовина	Оно чија вредност захтева заштиту.	Шта губимо ако је угрожена?
Рањивост	Слабост коју је могуће искористити.	Где систем нема довољну заштиту?
Претња	Могући узрок нежељеног исхода.	Ко или шта може активирати слабост?
Ризик	Комбинација вероватноће и последице.	Шта прво треба умањити?

Шема threat модела

Претња добија смисао тек када се веже за конкретну имовину, ток и последицу.



ЗАДАТАК

За сваки корак наведите ко га покреће, ко доноси одлуку и који траг остаје.

Читање архитектонске скице кроз безбедност

Од описа проблема до одлуке која може да се провери.

КОНТЕКСТ

Читање архитектонске скице кроз безбедност

Архитектонска скица добија безбедносну вредност када се преко компоненти уцртају подаци, идентитети и границе поверења. Није потребно цртати сваку класу. Довољно је показати делове кроз које пролази вредна информација и одлуке које мењају њен статус.

01

Означити улазе које контролише корисник или спољашњи сервис.

02

Означити место где се идентитет или дозвола поново проверавају.

03

Означити складишта, кључеве и интеграције које мењају последицу инцидента.

04

Уз сваку границу записати једну реалну претпоставку која може бити погрешна.

Модел пре контроле

Три правила која треба да остану видљива у имплементацији и ревизији.

01

**Имовина има власника, значај и
животни циклус.**

Јасно правило

02

**Спољна компонента не добија
поверење само зато што је
интегрисана.**

Проверљива примена

03

**Претња постаје корисна када
води до захтева, контроле и
начина провере.**

Видљив доказ

Како се ова тема види у развоју

Тема се види у малим одлукама током развоја, не само у завршној документацији.

РАЗВОЈНИ КОНТЕКСТ

Од принципа до радног кода

Архитектурни цртеж постаје радни алат када уз сваку важну границу наведе податке, актере и претпоставке. Тим затим бира мали број реалних мисусе сценарија и проверава их тестом или прегледом дизајна.

01

Именуј одлуку и њену границу.

02

Имплементирај проверу на серверу.

03

Додај позитиван и негативан доказ.

Пример: извоз из интерног система

Конкретан случај показује где опште правило постаје стварна одлука система.

СЦЕНАРИО

Пример: извоз из интерног система

Интерни сервис припрема извоз осетљивих података за други систем. Тим га доживљава као безбедан јер је сервис „унутра“, али сам прелазак података у други систем мења претпоставке. Потребно је знати који податак путује, ко прима податак, шта може поћи по злу и како систем спречава или бар открива нежељен исход.

01

Имовина се не своди на базу података: укључује налоге, кључеве, сервисне идентитете, конфигурацију и пословне записе.

02

Граница поверења може бити API позив, ред порука, административни интерфејс или извоз у датотеку.

03

Добар тхреат модел бира неколико реалних сценарија и уз сваки наводи контролу и начин провере.

Граница поверења тражи експлицитну проверу

Код почиње од исте леве ивице као наслов прозора и остаје читљив на пројектору.

```
1 public Result<Payment> Create(ExternalRequest input)
2 {
3     var command = validator.ParseAndValidate(input);
4     if (!trustPolicy.Accepts(command.Source, command.Signature))
5         return Result.Deny("untrusted_source");
6     if (command.Amount > limits.For(command.AccountId))
7         return Result.Deny("limit_exceeded");
8     return payments.Create(command);
9 }
```

ШТА ЈЕ ВАЖНО

Спољни улаз се прво валидира и доказује, па тек онда сме да покрене пословну промену.

ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Тест доказује да претња не стиже до имовине

Негативан тест није споредан случај — он описује где право престаје.

```
1 [Fact]
2 public void Untrusted_input_stops_at_the_boundary()
3 {
4     var request = ExternalRequest.WithInvalidSignature();
5
6     var result = service.Create(request);
7
8     result.Reason.Should().Be("untrusted_source");
9     repository.Writes.Should().Be(0);
10 }
```

ДОКАЗ

Очекивање није само одбијање, већ и да није направљен ниједан упис у заштићено стање.

ПРОВЕРА

Промените једну чињеницу и очекујте јасан, стабилан разлог одбијања.

Доказ мора да одговори шта се догодило

Чува се довољно контекста за реконструкцију, али не и тајне или непотребни лични подаци.

```
1 {  
2   "asset": "payment-ledger",  
3   "trustBoundary": "public-api",  
4   "threat": "forged-command",  
5   "control": "signature-validation",  
6   "test": "reject-invalid-signature",  
7   "residualRisk": "stolen-valid-key"  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, токен, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Три грешке које треба препознати одмах

Свака делује практично у првој итерацији, али касније постаје скривена безбедносна граница.

01

Инвентар који постоји само ради евиденције, без власништва и значаја.

Нема јасног власника одлуке.

02

Општи каталог претњи који није повезан са стварним системом.

Не постоји негативан сценарио.

03

Контрола изабрана пре разумевања ризика који треба да смањи.

Доказ не показује стварни исход.

Како threat модел остаје користан документ

Добар доказ је свеж, поновљив и довољно јасан да га други члан тима протумачи.

ОБРАЗЛОЖЕЊЕ

Како тхреат модел остаје жив документ

Модел претњи није документ који се напише једном на почетку семестра. Мења се када се дода нови улаз, интеграција, начин чувања података или привилегована радња. Свака већа архитектонска промена је прилика да се провери да ли су старе претпоставке и даље тачне.

01

Дијаграм се ажурира када ток података или граница поверења стварно промени понашање система.

02

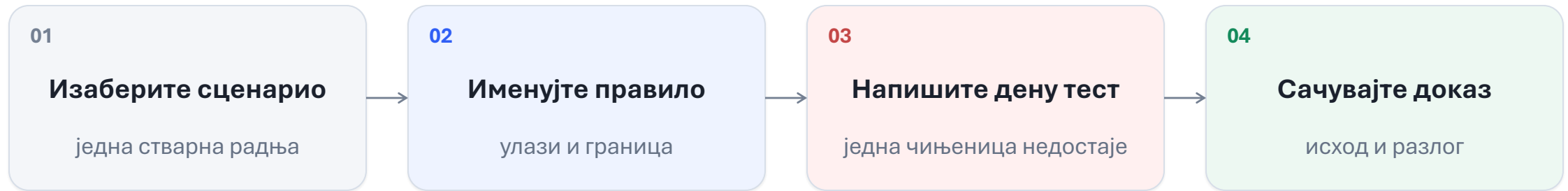
За одабрани сценарио постоји веза до контроле, теста или прегледа који га проверава.

03

Преостали ризик се записује јасно, уместо да се претвара да ниједна претња више не постоји.

Мини вежба за пројекат

На једном сценарију повежите одлуку, имплементацију, негативни тест и доказ.

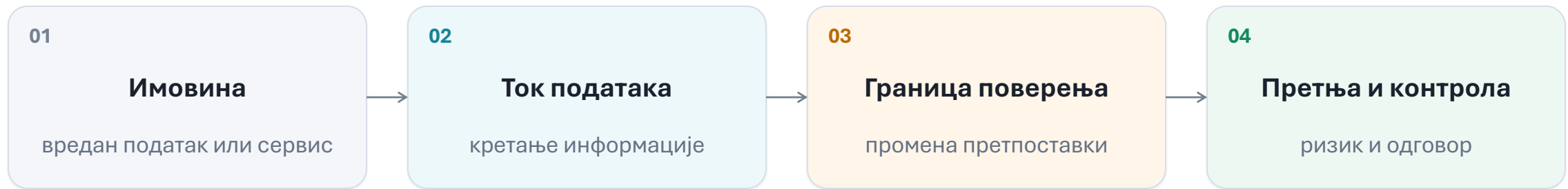


ЗАДАТАК ЗА ПРОЈЕКАТ

Примените тему „Имовина, границе поверења и threat modeling“ на додељену пројектну целину и припремите доказ који други члан тима може да понови.

Провера разумевања

Тема је савладана када одлуку можете да објасните без ослањања на назив framework-a.



ЗА ЗАВРШЕТАК

Нацртајте један ток осетљивог податка и означите место на коме се претпоставка о поверењу мења.

Следећи корак: применити исти модел на једну реалну границу у сопственом пројекту.